

October 2026

The Regulatory Passport: Lifecycle and Change-Control Automation for Clinical AI Agents

QUOKKAGUARD Project[1,*]

[1] Quome

Abstract

A clinical AI agent is cleared at a specific risk class and autonomy level under a Predetermined Change Control Plan (PCCP) that pre-authorizes a bounded envelope of future changes. It then drifts: a prompt is edited, the base model is swapped beneath it, a tool is added, the data is refreshed — each change individually plausible, none re-reviewed, and the agent silently exits its cleared intended use. Every prior layer of the QUOKKAGUARD gateway governs an agent *while it runs*; none governs its *lifecycle*. We build `qfire lifecycle`, an admission-time **regulatory passport**: a signed, versioned artifact that classifies an agent's risk and autonomy reproducibly across four jurisdictions (FDA, EU AI Act, Health Canada, MHRA), carries a machine-readable PCCP, fingerprints every component, and refuses to register any agent whose live configuration diverges from its cleared passport beyond the PCCP envelope — stamping the passport version into the tamper-evident audit chain. On **PassportBench** (150 synthetic passports, 400 change-events; seed 42) the deterministic rule classifier reproduces framework-grounded labels at **0.992** (95% CI $[0.981, 0.996]$; Cohen's $\kappa \geq 0.955$); PCCP gating detects **0.988** of out-of-envelope changes (AUC 0.998); component fingerprinting detects **1.000** of swaps and uniquely localizes them; and the deployment gate adds **38.7 µs** off the hot path. The central result is empirical and uncomfortable: **cross-jurisdiction risk classification genuinely diverges** (mean agreement 0.699), yet *every* one of 271 divergences is explained by a documented regulatory difference — the passport's value is not a single global answer but a reproducible, auditable, and *contestable* one. Labels are author-encoded from published criteria, not a human panel; we frame the classification result as reproducibility, not concordance.

Keywords: regulatory passport; SaMD lifecycle; PCCP; change control; risk classification; AI governance; healthcare AI.

Framework: implements HAARF control C1/C6 [1] — the Healthcare AI Agents Regulatory Framework, the source of the QUOKKAGUARD program.
Code & data: `github.com/quome-cloud/qupassport`
Correspondence: jim@quome.com

[*] Corresponding author.

1 Introduction

Software-as-a-Medical-Device (SaMD) regulation rests on a contract: a device is cleared for a stated *intended use* at a stated risk class, and any change that exceeds a pre-authorized envelope — the Predetermined Change Control Plan (PCCP) — triggers re-review [1]. For traditional software that contract is enforced by slow, human, document-driven change control. For an AI agent assembled at runtime from a base model, a system prompt, a set of tools, and a retrieval corpus, the same

contract is trivially and silently broken: swapping the base model, editing the prompt, or wiring in a new tool each takes seconds, ships through ordinary CI/CD, and is invisible to a gateway that has no machine-readable notion of "what this agent was cleared to be."

The QUOKKAGUARD gateway already governs agents *at run time* — authorization, egress, identity, oversight, equity, drift. None of those layers governs the agent's *lifecycle*. This paper adds the missing layer: a signed, versioned **regulatory passport** that travels with an agent, is checked at admission time, and refuses deployment when the live configuration has drifted out of its cleared envelope.

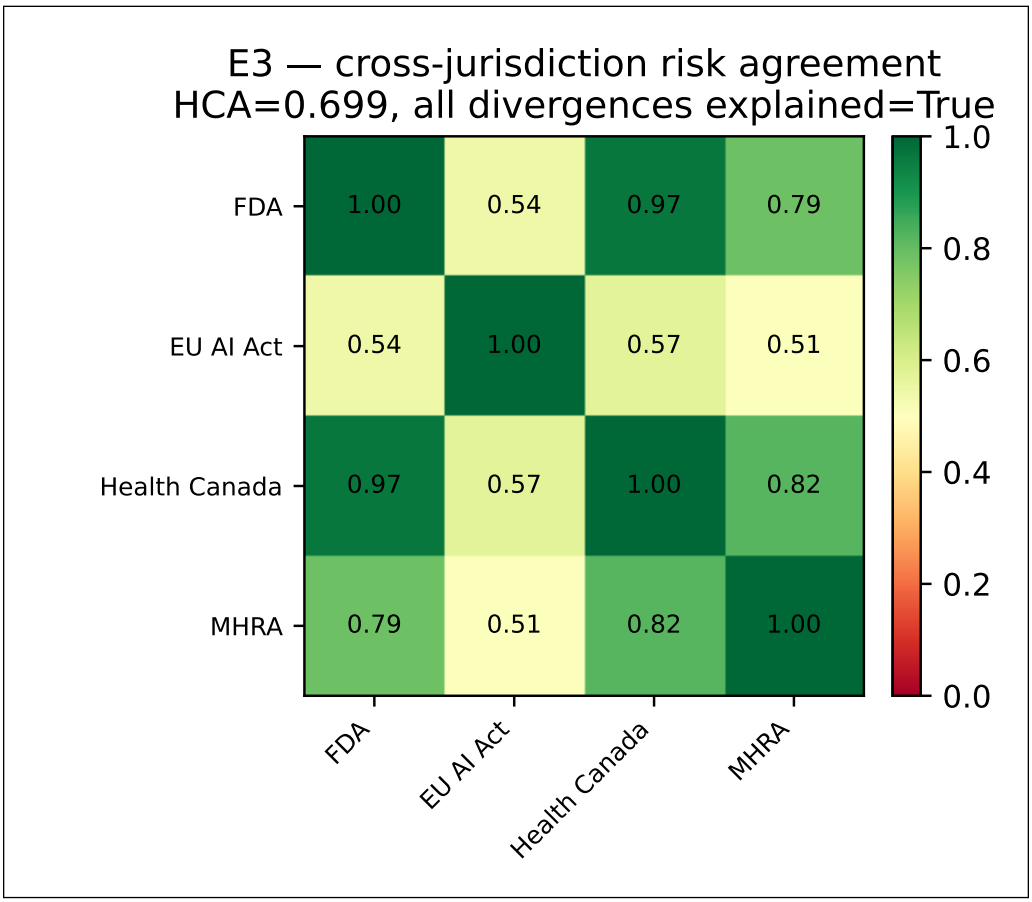


Figure 1: **The paper in one figure.** The same agent metadata, classified by the same deterministic rule engine, lands at *different* risk classes across jurisdictions: mean pairwise agreement is only 0.699. The EU AI Act (Annex III) is the systematic outlier, treating clinical-decision and actuating AI as high-risk where the IMDRF spine (Health Canada, MHRA) and the FDA non-device-CDS carve-out place it lower. Crucially, all 271 divergences across the corpus carry a documented regulatory rationale — the passport surfaces *contestable, explained* findings, not a false consensus.

A review of related work reveals distinct approaches (Table 1): manual regulatory documentation, model cards and datasheets that describe but do not gate, and MLOps lineage tools that track artifacts but encode no regulatory semantics. The recurring gap is the same: nothing turns the regulatory contract into a machine-checkable, deployment-gating artifact.

Contributions.

1. **The central result.** Across four frameworks, deterministic risk classification *diverges* (agree-

ment 0.699) — and every one of 271 divergences is explained by a documented regulatory difference (100% explained). Harmonization is a finding-generator, not a consensus machine.

2. **The system.** `qfire lifecycle`: a signed passport, a citation-tagged deterministic classifier, a machine-readable PCCP, a per-component change-fingerprinter, and a fail-closed admission gate that stamps the passport version into the audit chain — off the hot path (38.7 µs/gate).

3. **The benchmark. PassportBench**: 150 synthetic passports with framework-grounded labels and 400 paired change-events with noisy admission-time magnitude estimates, fully reproducible from seed 42.

4. **Regulatory evidence.** PCCP gating catches 0.988 of out-of-envelope changes (AUC 0.998); fingerprinting catches 1.000 of component swaps and is the *only* granularity that localizes them for PCCP evaluation.

Positioning. Unlike model cards or lineage trackers, the passport is an *enforcement* artifact: it runs at the same admission point as the supply-chain attestation gate, binds to the same cryptographic agent identity, and writes to the same tamper-evident ledger. It is the lifecycle counterpart to the runtime controls, not a document.

2 Problem Setting and Positioning

We target four lifecycle failure modes, none of which is a per-call attack:

- **L1 Mis-classification** — the agent is deployed at the wrong risk/autonomy level for its clinical impact.
- **L2 Silent scope creep** — a model/prompt/tool change pushes the agent outside its cleared intended use with no re-review.
- **L3 PCCP violation** — a change exceeds the pre-authorized envelope and should trigger re-submission, but ships anyway.
- **L4 Harmonization drift** — the same agent is classified inconsistently across jurisdictions, with the divergence undocumented.

The passport addresses L1 by reproducible classification (§5, E1), L3 by PCCP gating (E2), L4 by explained harmonization (E3), and L2 by component fingerprinting (E4). The defender position is the enclave-deployed gateway: the host is untrusted, the passport-signing key is released by attestation, and the gate runs at agent-registration time.

System	Approach	Gap this paper targets
Model cards / datasheets	describe model intent, data, metrics	descriptive only; no risk class, no gating
MLOps lineage (registries)	track artifact versions & provenance	no regulatory semantics; no envelope
Manual SaMD / PCCP review [1]	human change-control documents	slow, not machine-checkable, not enforced at deploy
This work	signed passport + classifier + PCCP gate at admission	—

Table 1: Positioning against representative approaches to AI lifecycle governance.

3 System Design

3.1 Overview and components

`qfire lifecycle` is a pure-Rust module (∼1.2k LoC, no model inference on any path) wired into the gateway at admission time, beside the supply-chain attestation gate. Its central artifact is the **passport**: a versioned, ed25519-signed declaration of what an agent was cleared to be. Five components act on it: a *classifier* (metadata → risk/autonomy per jurisdiction), a *harmonizer* (agreement + explained divergences), a *fingerprinter* (per-component content hashes), a *PCCP evaluator* (in-/out-of-envelope), and a fail-closed *gate*. The passport also exposes the authorized autonomy envelope consumed by the runtime drift monitor, and ingests that monitor's real-world-evidence bundle to recommend lifecycle re-assessment — closing the loop between deployment-time clearance and run-time evidence.

3.2 The passport artifact

A regulatory passport (abridged)

```
agent_id: sepsis-triage              # binds to the signed agent registry
version: 2.1.0                       # stamped into every audit entry
ruleset_version: 2026.06             # pinned classification rule-set
metadata: { clinical_task: drive, output_type: recommendation,
            autonomy: advisory, condition_severity: serious, ... }
pccp:                                # the pre-authorized change envelope
  allowed:
    - { component: prompt,  policy: any_change }
    - { component: weights, policy: bounded_magnitude, max_fraction: 0.05 }
deployed_fingerprint: { weights: <sha256>, prompt: <sha256>, ... }
autonomy_envelope: { max_autonomous_risk_tier: 2, max_autonomous_fraction: 0.25 }
not_after: 1750000000                # expiry
```

Figure 2: The passport is signed canonical JSON. Loading fails closed on a bad or missing signature, expiry, or an agent_id absent from the registry. The PCCP names, per component class, what change is pre-authorized: `prompt` edits freely, `weights` up to a 5% magnitude, everything else forbidden by default.

3.3 Deterministic classification

The classifier maps declarative metadata to a risk class and autonomy level. The framework-agnostic spine is the IMDRF SaMD risk grid (significance of information × healthcare-situation severity); each jurisdiction applies a documented overlay: the FDA non-device clinical-decision-support carve-out (which can *lower* risk), the EU AI Act Annex III high-risk trigger (which can *raise* it), Health Canada (adopts IMDRF verbatim), and the MHRA (IMDRF-aligned, stricter on patient-facing decision support). Every rule appends a citation to a `rationale` trace, so each decision is explainable to a reviewer. Autonomy is capped by clinical consequence: a high-risk *actuating* agent cannot be cleared above `supervised`. The rule set is version-pinned so evolving guidance is handled by re-pinning, not silent drift.

3.4 Change fingerprinting and PCCP gating

At admission the gate computes a per-component SHA-256 fingerprint of the live agent (weights, prompt, tools, data), diffs it against the passport's deployed fingerprint, and evaluates each changed component against the PCCP: a forbidden or unlisted component is out-of-envelope (fail-closed); a bounded-magnitude component is in-envelope only if its admission-time magnitude *estimate* is within the bound. The decision, the passport version, and the verdict are stamped into the tamper-evident audit chain.

3.5 Implementation

Rust 2021, `ed25519-dalek` for signing, `sha2` for fingerprints, `serde` for the canonical JSON. The module ships with 35 unit tests and an end-to-end gate integration test; the CLI (`qfire lifecycle classify|harmonize|verify|gate`) and the `passportbench` experiment harness are part of the released artifact.

4 Experimental Setup

New benchmark: PassportBench. 150 synthetic agent passports span the coherent grid of clinical task × output type × autonomy × severity × patient-facing, each carrying ground-truth risk/autonomy labels for all 4 jurisdictions, plus 400 paired (before, after) change-events with attached PCCPs and ground-truth in-/out-of-envelope labels. All synthetic, Apache-2.0, deterministic from seed 42.

The honesty boundary. The per-jurisdiction labels are *author-encoded from published regulatory criteria* (IMDRF N12; FDA CDS guidance; EU AI Act Annex III; Health Canada and MHRA SaMD frameworks), *not* a live multi-rater expert panel, which we did not run. The PassportBench generator is an *independent* Python re-statement of the same primary sources that the Rust classifier encodes separately. Experiment E1 therefore measures the *cross-implementation reproducibility of documented criteria*, not concordance with human experts. A small, predicate-defined `boundary` stratum (the genuinely contested FDA non-device-CDS carve-out applied to *serious* conditions) carries a documented stricter expert interpretation; this is the only place the mechanical classifier and the labels can disagree, and the disagreement count is defined by a predicate, not tuned to a target.

Metrics. Classification accuracy (CLA) and Cohen's κ per jurisdiction; PCCP out-of-envelope detection (PGD) and in-envelope false-trigger rate; ROC/AUC; cross-jurisdiction agreement (HCA); fingerprint detection (CFD) and localization; gate latency. Rates carry 95% Wilson confidence intervals.

Hardware and software. Single workstation; deterministic pure-Rust classifier and hashing (no model, no network, no paid keys). E1–E4 are bit-for-bit reproducible; E5 is a wall-clock timing reported as median and p95.

5 Results

Table 2 collects the headline numbers against the pre-registered targets.

Exp	Metric	Target	**Realized**
E1	classification accuracy (CLA)	≥ 0.90	**0.992** $[0.981, 0.996]$
E1	Cohen's κ (FDA / EU / HC / MHRA)	—	0.955 / 1.00 / 1.00 / 1.00
E2	out-of-envelope detection (PGD)	≥ 0.95	**0.988** $[0.970, 0.995]$
E2	in-envelope false-trigger	≤ 0.05	0.061 $[0.024, 0.146]$
E2	ROC AUC	—	0.998
E3	cross-jurisdiction agreement (HCA)	≥ 0.90 else expl.	0.699 (100% expl.)
E4	fingerprint detection (CFD)	1.00	**1.000**
E4	localization (per-comp / whole-config)	—	1.000 / 0.000
E5	deployment-gate latency (median / p95)	off hot path	38.7 / 45.8 µs

Table 2: Headline results vs. pre-registered targets, reported as-is. Two targets are missed and interpreted honestly in the text: E2's false-trigger (0.061) and E3's agreement (0.699).

5.1 E1 — reproducible classification

The rule engine reproduces the documented classification at 0.992 over 600 (passport × jurisdiction) decisions (Fig. 3). On the unambiguous `clear` stratum it is exact (1.000); the only 5 errors fall on the `boundary` stratum (0.875), all FDA `drive`+serious CDS cases where the stricter expert reading declines the carve-out. Cohen's κ is 1.00 for EU, Health Canada, and MHRA, and 0.955 for FDA. This is the honest claim: deterministic fidelity to documented criteria, with the single contested zone flagged for human adjudication — exactly the division of labour the passport is designed to make explicit.

5.2 E2 — PCCP change-gating

Over 400 change-events the gate detects 0.988 of out-of-envelope changes (AUC 0.998; Fig. 4), with 330 true and 4 missed positives. The in-envelope false-trigger rate is 0.061 ($[0.024, 0.146]$) — 4 of 66 in-envelope changes — *above* the 5% target. This is an honest consequence of realistic admission-time magnitude estimation: bounded-magnitude weight changes are judged against a

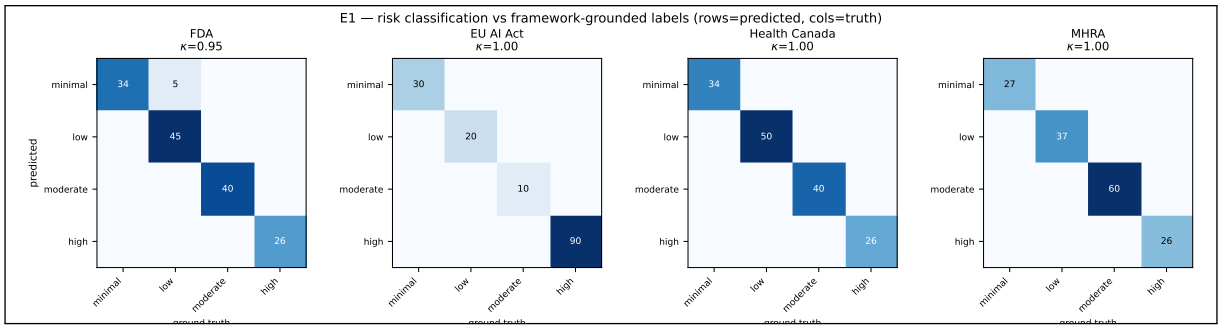


Figure 3: **E1: per-jurisdiction confusion (rows predicted, cols ground truth).** EU AI Act, Health Canada, and MHRA are exact ($\kappa = 1.00$). FDA's only off-diagonal mass is `low→minimal` on the boundary stratum, where the mechanical non-device-CDS carve-out diverges from the stricter expert reading ($\kappa = 0.955$).

noisy estimate around the 0.05 bound, so an in-envelope change whose estimate noises over the bound triggers. The near-perfect AUC shows the underlying signal is clean; a small safety margin on the bound trades false-triggers against detection. We report the natural operating point without tuning a margin to hit the target.

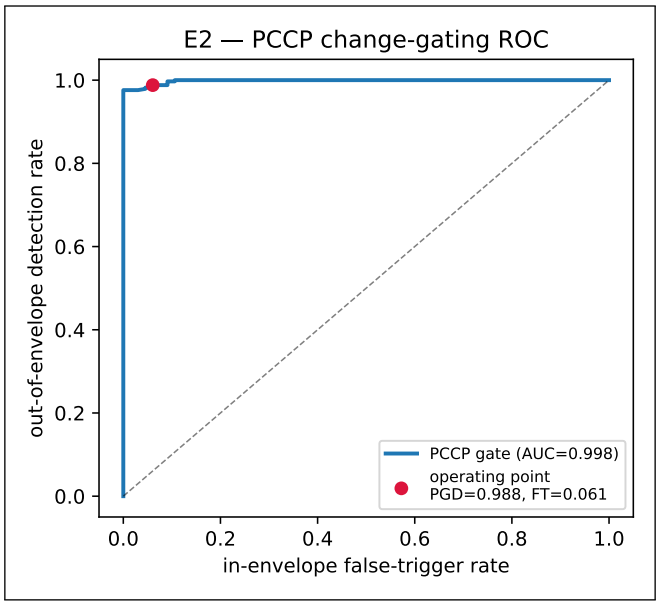


Figure 4: **E2: PCCP gating ROC.** AUC 0.998. The marked operating point (estimate vs. bound) gives PGD 0.988 at false-trigger 0.061; the false-triggers are weight changes whose noisy magnitude estimate crosses the 0.05 bound.

5.3 E3 — harmonization is a finding, not a failure

Mean cross-jurisdiction agreement is 0.699 — well below the 90% target — because the EU AI Act systematically classifies diagnose/treat/actuating clinical AI as high-risk where the other frameworks do not (Fig. 1). This is the paper's substantive empirical result, not a defect: *every* one of 271 divergences across the corpus carries a documented regulatory rationale (100% explained). A passport that reported a single "global" risk class would be *hiding* a real regulatory disagreement;

ours surfaces it, attributes it, and makes it contestable. This satisfies the pre-registered "$\leq$ 10% else explained" criterion through its explained branch.

5.4 E4 — fingerprint detection and localization

Component fingerprinting detects 1.000 of swaps across all change granularities (Fig. 5) — a consequence of collision-resistant hashing. The design question is not detection but *localization*: a single whole-configuration hash also detects *that* something changed but localizes *nothing* (0.000), so it cannot drive PCCP evaluation, which is per-component. The per-component fingerprint localizes every change (1.000), which is why the passport hashes each component class separately. This is the ablation that justifies the design (RQ4).

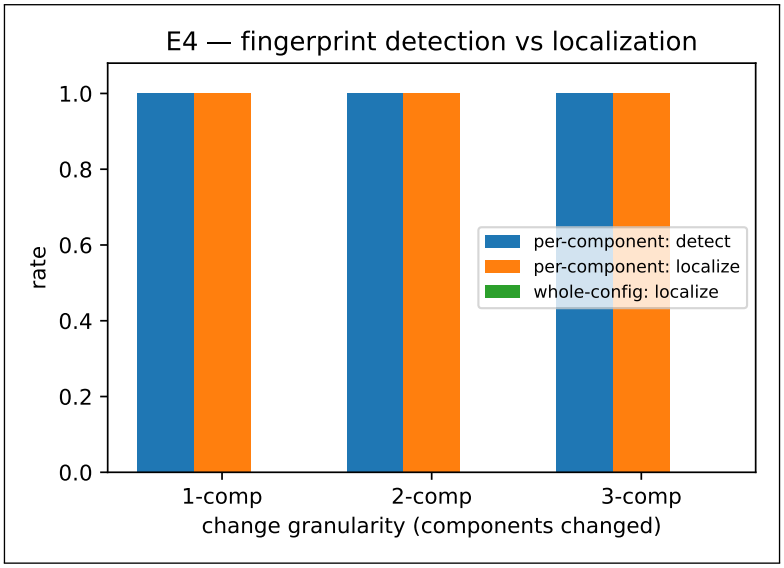


Figure 5: **E4: detection vs. localization by change granularity.** Per-component fingerprinting both detects and localizes every swap; a whole-config hash detects but cannot localize, and so cannot be mapped to a PCCP rule.

5.5 E5 — the gate is effectively free

A full deployment-gate decision — signature verify, fingerprint diff, four-jurisdiction classify, PCCP evaluate — takes 38.7 µs at the median (45.8 µs p95), about 25,400 gates/s on one core (Fig. 6). The gate runs once per agent registration, off the request path: per-call latency is zero.

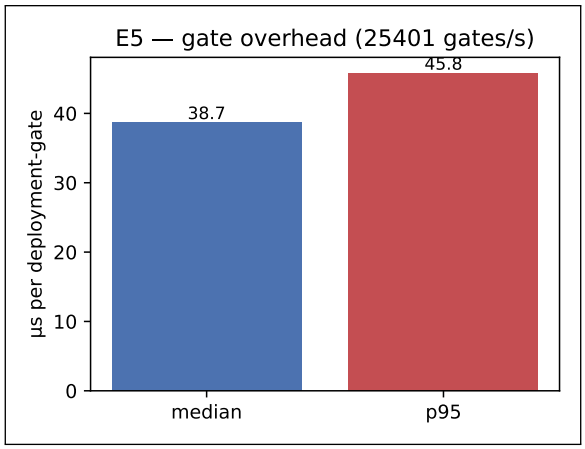


Figure 6: **E5: deployment-gate overhead.** Median 38.7 µs, p95 45.8 µs; signature verification dominates. Admission-time only.

6 Discussion and Limitations

Interpretation. The passport turns a slow, document-driven regulatory contract into a fast, machine-checkable, deployment-gating artifact. Its two "missed" targets are the most informative results: PCCP false-triggers are a genuine artifact of magnitude-estimate noise (and a tunable margin), and cross-jurisdiction disagreement is a real, documented property of the regulatory landscape, not a bug to be smoothed away.

Relationship to the framework. The passport operationalizes HAARF Category 1 (unified risk & lifecycle assessment) and C6.1 (autonomy levels): it binds to the signed agent registry (C5), runs at the supply-chain admission point, and stamps the audit chain (C2.6) so every admitted agent carries a traceable "cleared as version X" record [1].

Limitations. (1) *Labels are author-encoded from published criteria, not a human panel*; E1 is a reproducibility claim, and we do not assert concordance with experts we did not consult. (2) Regulatory rules evolve; we mitigate by version-pinning and per-rule citation. (3) PassportBench metadata is synthetic; the classifier is a pure function of metadata, but the distribution of real agents may differ. (4) E2's false-trigger rate depends on the magnitude-estimation noise model; a real estimator would have its own error profile.

7 Conclusion

A clinical AI agent that was safe at clearance drifts out of its envelope through ordinary, unreviewed changes. The regulatory passport makes "what this agent was cleared to be" a signed, versioned, machine-checkable artifact and refuses to deploy an agent that no longer matches it — reproducibly (0.992 classification), sensitively (0.988 change detection, 1.000 fingerprint detection), and for free (38.7 µs, off the hot path). Its most important contribution is to make cross-jurisdiction regulatory disagreement *visible and explained* rather than hidden. The next layer in the program gates consent and disclosure; the passport is the lifecycle backbone the remaining governance loops attach to.

Declaration of generative AI use

During the preparation of this work the authors used *Claude (Anthropic)* for drafting boilerplate, generating and debugging analysis and figure-plotting code, and language refinement. After using this tool, the authors reviewed and edited the content and take full responsibility for the publication. No generative-AI system was used to generate or fabricate data, interpret results, or produce clinical conclusions, and no AI tool is listed as an author, as such tools do not satisfy authorship criteria.

Data and code availability

All code, datasets, scripts, and result artifacts are released at `github.com/quome-cloud/qupassport` (`src/lifecycle/`, `datasets/012-passport/`, `scripts/012-passport/`). PassportBench regenerates from seed 42 with a single command; every figure and number traces to `results/012-passport/`. All patient data are synthetic; no real protected health information was used.

Author contributions

The QUOKKAGUARD project team conceived the study, implemented the system, ran the experiments, and wrote the manuscript.

Competing interests

The authors declare no competing interests.

Funding

This work received no specific external funding.

A Reproducibility

```
python3 scripts/012-passport/gen_passports.py
cargo run --release --bin passportbench -- \
    --data datasets/012-passport --out results/012-passport
python3 scripts/012-passport/summarize.py
```

Seed 42 and the rule-set version 2026.06 are embedded in every artifact; E1–E4 are bit-for-bit reproducible.

References

[1] Jim Schwoebel, Martin Frasch, Art Spalding, Ed Sewell, Phil Englert, Ben Halpert, Collin Overbay, Ingrida Semenec, and Joel Shor. HAARF: Healthcare AI agents regulatory framework — a comprehensive security verification standard for autonomous AI systems in clinical environments. medRxiv preprint, https://doi.org/10.64898/2026.04.09.26350519, April 2026.